

PASSWORD VAULT & CREDENTIAL MANAGEMENT SYSTEM

Project Manual & Complete Postman API Testing Reference

Project Overview & Postman Environment Settings:

- Base URL: `http://localhost:8080`
- Auth Header: Authorization: Bearer <jwt_token>
- Content-Type: application/json
- Architecture: Zero-Knowledge Client-Side AES-256-GCM Encryption + Spring Boot REST APIs + PostgreSQL Database

1. Authentication & Session Management APIs

POST	<code>http://localhost:8080/api/auth/send-otp?email={email}</code> (Public)
Description	Send 6-digit Registration OTP email
Request Payload	None (Query Param)
Expected Response	<code>{"success":true, "message":"OTP sent to email"}</code>

POST	<code>http://localhost:8080/api/auth/verify-otp?email={email}&otp={code}</code> (Public)
Description	Verify Registration OTP
Request Payload	None (Query Param)
Expected Response	<code>{"success":true, "message":"OTP verified"}</code>

POST	<code>http://localhost:8080/api/auth/register</code> (Public)
Description	Register new user account
Request Payload	<code>{ "fullName": "Sanjaya Dakua", "username": "09Sanjaya", "email": "sanjaya@gmail.com", "password": "Pass123!" }</code>
Expected Response	<code>{ "token": "eyJhbGciOi...", "type": "Bearer", "email": "sanjaya@gmail.com" }</code>

POST	<code>http://localhost:8080/api/auth/login</code> (Public)
Description	Authenticate user & issue JWT token
Request Payload	<code>{ "email": "sanjaya@gmail.com", "password": "Pass123!" }</code>
Expected Response	<code>{ "token": "eyJhbGciOi...", "type": "Bearer", "id": 1 }</code>

POST	<code>http://localhost:8080/api/auth/forgot-password/send-otp</code> (Public)
Description	Send Password Reset OTP
Request Payload	<code>{ "email": "sanjaya@gmail.com" }</code>
Expected Response	<code>{ "success": true, "message": "Reset OTP sent" }</code>

POST	http://localhost:8080/api/auth/reset-password (Public)
Description	Reset account master password using OTP
Request Payload	{ "email": "sanjaya@gmail.com", "otp": "123456", "newPassword": "NewPass123!" }
Expected Response	{ "success": true, "message": "Password reset successfully" }

POST	http://localhost:8080/api/auth/logout (Bearer JWT)
Description	Invalidate user session
Request Payload	None
Expected Response	{"success":true, "message":"Successfully logged out"}

GET	http://localhost:8080/api/auth/logs (Bearer JWT)
Description	Fetch user login activity history
Request Payload	None
Expected Response	[{ "id": 1, "email": "sanjaya@gmail.com", "loginStatus": "SUCCESS" }]

2. Password Vault Credential CRUD APIs

POST	http://localhost:8080/api/vault/items (Bearer JWT)
Description	Save new encrypted vault item
Request Payload	{ "title": "Tata Power", "username": "sanjaya9090@gmail.com", "encryptedPassword": "CipherBase64==", "iv": "IvBase64==", "category": "WORK", "notes": "Tata Employee" }
Expected Response	{ "id": "uuid-123", "title": "Tata Power", "shared": false }

GET	http://localhost:8080/api/vault/items (Bearer JWT)
Description	Fetch all credentials owned or shared
Request Payload	None
Expected Response	[{ "id": "uuid-123", "title": "Tata Power", "encryptedPassword": "..." }]

GET	http://localhost:8080/api/vault/items/{id} (Bearer JWT)
Description	Fetch vault credential by ID
Request Payload	None
Expected Response	{ "id": "uuid-123", "title": "Tata Power" }

PUT	http://localhost:8080/api/vault/items/{id} (Bearer JWT)
Description	Update credential title, payload or notes
Request Payload	<pre>{ "title": "Tata Power Corporate", "username": "sanjaya9090@gmail.com", "encryptedPassword": "NewCipher==", "iv": "NewIv==" }</pre>
Expected Response	<pre>{ "id": "uuid-123", "title": "Tata Power Corporate" }</pre>

DELETE	http://localhost:8080/api/vault/items/{id} (Bearer JWT)
Description	Delete vault credential (Full Management required)
Request Payload	None
Expected Response	<pre>{"success":true, "message":"Item deleted"}</pre>

PATCH	http://localhost:8080/api/vault/items/{id}/favorite (Bearer JWT)
Description	Toggle favorite status
Request Payload	None
Expected Response	<pre>{ "id": "uuid-123", "favorite": true }</pre>

3. Credential Sharing & Access Control APIs

PATCH	http://localhost:8080/api/vault/items/{id}/permission?level={level}&recipientEmail={email} (Bearer JWT)
Description	Share credential with user (Levels: VIEW_ONLY, EDIT_ACCESS, FULL_MANAGEMENT)
Request Payload	Body Payload (Optional AES Re-encryption): <pre>{ "encryptedPassword": "SharedKeyCipher==", "iv": "SharedIv==" }</pre>
Expected Response	<pre>{ "id": "uuid-123", "title": "Tata Power", "permissionLevel": "VIEW_ONLY", "shared": true }</pre>

4. Security Monitoring & Auditing APIs

GET	http://localhost:8080/api/security/audit-logs (Bearer JWT)
Description	Fetch user security audit log events
Request Payload	None
Expected Response	<pre>[{ "action": "Credential Created", "timestamp": "2026-09-02T19:40:00" }]</pre>

GET	http://localhost:8080/api/security/alerts (Bearer JWT)
Description	Fetch active security alerts
Request Payload	None
Expected Response	<pre>[{ "status": "ACTIVE", "description": "Failed login attempt detected" }]</pre>

GET	http://localhost:8080/api/security/suspicious-activities (Bearer JWT)
Description	Fetch suspicious activity log entries
Request Payload	None
Expected Response	[{"activityType": "FAILED_LOGIN_BURST", "status": "FLAGGED"}]

5. Security Analytics & Health Reports APIs

GET	http://localhost:8080/api/reports/password-health (Bearer JWT)
Description	Fetch vault password health score & weak analysis
Request Payload	None
Expected Response	{ "healthScore": 85.0, "totalPasswords": 4, "weakPasswords": 0, "reusedPasswords": 0 }

GET	http://localhost:8080/api/reports/login-activity (Bearer JWT)
Description	Fetch login activity statistics & logs
Request Payload	None
Expected Response	{ "totalAttempts": 12, "successfulLogins": 10, "failedLogins": 2, "successRate": 83.3 }

6. Milestone 4 Task 1 Testing Validation Summary

Test Feature	Expected Result	Actual Result	Status
User Registration	Account created & OTP verified	Account created in users table	PASS
Invalid Login	400 Bad Request error returned	400 Bad Request with error msg	PASS
Vault Credential Add	AES payload saved in DB	Saved in vault_items table	PASS
Credential Sharing	Recipient copy generated with level	Recipient item created with level	PASS
View Only Edit Denied	400 Bad Request permission error	400 Bad Request permission error	PASS
Password Health Report	Calculates vault strength score	Calculates score & weak count	PASS